Mercury Security (HID Global) Firmware Attack Surface & Detection Brief

Mercury Security (HID Global) Firmware Attack Surface & Detection Brief

Scope: CVE and public-advisory research only — firmware has not yet been acquired or extracted (the HID Global partner portal requires a login this project does not have). No direct binary examination; findings below are from public vulnerability disclosures, vendor advisories, and product documentation. No hashes, extracted file listings, or service-enumeration output exist for this vendor yet — this brief will need a second pass once LP/EP/MR firmware is actually pulled from a partner-portal account or desoldered from staged hardware.

Purdue layer mapping: Mercury LP/EP controllers sit at **Purdue L1 (Basic Control/Field Device layer)** — they are the field devices that directly execute the physical-security "process loop": read a credential or REX input, evaluate it, and actuate a door-strike/maglock relay, exactly analogous to how a PLC in purdue-l1-basic-controllers-brief.md directly actuates a physical output from a sensor input. That brief's current catalog is industrial-process controllers (chassis/compact PLCs, RTUs, protective relays, drives) and does not yet include a physical-security/access-control device class — Mercury panels are flagged here as the same Purdue role (L1 field device with direct physical actuation) in a different domain (door hardware instead of process equipment), the same way the Eaton brief flagged UPS MCUs as "L0/L1-adjacent, included for completeness." MR-series SIO/reader boards sit one level below the LP/EP panel itself (OSDP/Wiegand field bus to the actual door hardware) — effectively **L0/L1 boundary**, equivalent to a remote I/O module hanging off a PLC.

Architecture grouping (drives the threat model, not the SKU)

Class	Purdue layer	Products	Stack	CVE coverage
A. LP Series intelligent controllers	L1 Basic Control (field device)	LP1501, LP1502, LP2500, LP4502	Embedded Linux, web UI (CGI binaries incl. `edit_route.cgi`), OSDP File Transfer page, host-comm protocol to the access-control software (Lenel OnGuard, Software House C•CURE, Genetec Synergis, Keri Doors.NET, etc.)	8 CVEs (2022), all CVSS 5.3-10.0
B. EP Series intelligent controllers	L1 Basic Control (field device)	EP4502	Same codebase/firmware family as LP, separate version track (1.29x vs LP's 1.30x)	Same 8-CVE family, EP-specific fixed versions

Class	Purdue layer	Products	Stack	CVE coverage
C. OEM-rebadged LP/EP hardware	L1 Basic Control (field device)	Carrier/LenelS2: LNL-X2210, LNL-X2220, LNL-X3300, LNL-X4420, LNL-4420, S2-LP-1501, S2-LP-1502, S2-LP-2500, S2-LP-4502	Identical Mercury silicon/firmware, Carrier/LenelS2 branding and web-UI skin ("LENEL•S2" header in place of Mercury's own)	Same 8-CVE family — confirmed via Carrier PSIRT (CARR-PSA-006-0622) and Honeywell Security Notice (SN-2022-06-02-01), both re-publishing the identical CVE set against their own rebadged part numbers
D. MR Series SIO/reader boards	L0/L1 boundary (field bus to door hardware)	MR16IN (input/alarm module), MR50/MR52 Series 3 (dual reader interface), MR62e, others	Bare-metal SIO firmware, OSDP (incl. OSDP Secure Channel/AES) or Wiegand to readers, addressed over the Mercury internal bus by the parent LP/EP panel	**No public CVE found against MR-board firmware itself as of this research** — the OSDP protocol-level weaknesses below are vendor-agnostic and were disclosed by third-party researchers, not as Mercury-specific CVEs

The OEM-rebadge pattern (Group C) is the single most important fact for this vendor: **Mercury itself has no retail brand presence** — the same LP/EP board, running the same firmware, ships inside more than 20 different OEM-branded access-control product lines (Carrier/LenelS2, Honeywell/Pro-Watch via LenelS2 integration, and others), per Trellix's 2022 research as reported by The Hacker News. A Mercury firmware CVE is therefore not "one vendor's problem" — it propagates to every integrator's SKU built on the same controller, and the branded documentation (web UI header, part number, PSIRT bulletin) can differ completely from the underlying Mercury model number, which is why both Carrier and Honeywell independently published the identical CVE-2022-31479…31486 set against their own part numbers in the same week.

Confirmed CVEs (LP/EP intelligent controller family — 2022, single disclosure cluster)

All eight CVEs come from one coordinated disclosure: independent penetration testing (Trellix) against HID Mercury Intelligent Controllers, published via Carrier PSIRT (CARR-PSA-006-0622) and CISA (ICSA-22-153-01) on 2022-06-02, and separately re-published by Honeywell (SN-2022-06-02-01) against the LenelS2-rebadged part numbers. **No CVEs against this product family have been published since 2022**, as of this research (checked NVD, CISA ICS advisories, and vendor PSIRT pages; the only newer CISA advisory found that mentions LenelS2 — ICSA-24-151-01, May 2024 — covers the separate LenelS2 NetBox software platform, not Mercury panel firmware, and is not included below).

CVE	CVSS v3.1	Product	Vector	Fixed firmware
CVE-2022-31479	9.6 Critical	LP1501/1502/2500/4502, EP4502	Unauthenticated hostname-field OS command injection, executed during core-collection/startup — persistent root access	LP/X/S2: 1.302, LNL-4420: 1.296

CVE	CVSS v3.1	Product	Vector	Fixed firmware
CVE-2022-31480	7.5 High	LP1501/1502/2500/4502, EP4502	Unauthenticated arbitrary firmware upload → forced reboot / DoS	LP/X/S2: 1.302, LNL-4420: 1.296
CVE-2022-31481	**10.0 Critical**	LP1501/1502/2500/4502, EP4502	Unauthenticated classic buffer overflow via crafted update file → arbitrary code execution	LP/X/S2: 1.302, LNL-4420: 1.296
CVE-2022-31482	9.0 Critical	LP1501/1502/2500/4502, EP4502	Unauthenticated crafted HTTP request → buffer overflow → segfault/reboot (automatable persistent DoS)	1.29 (all families)
CVE-2022-31483	9.1 Critical	LP1501/1502/2500/4502, EP4502	Authenticated path traversal (`..` / `/` in upload filename) → overwrite arbitrary system files, install startup service → root on underlying Linux	1.271 (all families)
CVE-2022-31484	7.5 High	LP1501/1502/2500/4502, EP4502	Unauthenticated crafted packet deletes a web-interface user → locks out legitimate admins, forces physical dip-switch recovery	1.29 (all families)
CVE-2022-31485	5.3 Medium	LP1501/1502/2500/4502, EP4502	Unauthenticated crafted packet rewrites the web-UI home-page "notes" field	1.29 (all families)
CVE-2022-31486	8.8 High	LP1501/1502/2500/4502, EP4502	Authenticated OS command injection via crafted route sent to `edit_route.cgi`	LP/X/S2: 1.303, LNL-4420: 1.297

Per Carrier's PSA, "prior generations of HID Mercury controllers are not impacted" — the advisory is explicit that this is a current-generation LP/EP finding, not a legacy-hardware one. Trellix publicly stated it chained two of these eight to reach remote root; neither Trellix's public writeup nor the vendor advisories specify which two, so treat the whole cluster as a chainable set rather than eight independent low-value bugs — CVE-2022-31481 (unauthenticated buffer overflow, 10.0) paired with CVE-2022-31483 (authenticated path traversal, 9.1) is the most plausible pairing give the described impacts (code execution → filesystem persistence), but this project has not verified that pairing independently.

No CVE found specific to the MR-series SIO/reader boards as of this research. The closest public research is Bishop Fox's "Badge of Shame" talk (Black Hat USA 2023), which disclosed protocol-level weaknesses in OSDP itself (not a Mercury CVE): if a reader/panel is left in Install Mode, an attacker can intercept the Secure Channel key-negotiation and impersonate a device; a downgrade attack can also convince a controller that an encrypted reader only supports cleartext. This is vendor-agnostic — Genetec's public response claims current Mercury and Axis devices require an installer to actively re-enable Install Mode via a physical configuration card/app rather than leaving it always-on, but that is a vendor claim, not an independently verified fix, and this project has not confirmed it against any specific MR-board firmware revision.

Top attack vectors (MITRE ATT&CK for ICS)

1. **T0819 Exploit Public-Facing Application** — six of the eight 2022 CVEs (31479, 31480, 31481, 31482, 31484, 31485) require **no authentication at all** against the panel's own web interface. Any LP/EP panel reachable from a compromised IT segment, a badge-reader VLAN with weak segmentation, or the open internet (these panels have shown up in Shodan-style exposure in past research) is remotely exploitable with the panel's native protocol — no credential theft needed first.
2. **T0857 System Firmware** — CVE-2022-31480 (unauthenticated firmware upload) and CVE-2022-31481 (buffer-overflow-in-update-file RCE) both target the firmware-update path itself. An attacker who can reach the panel can push a malicious update without logging in.
3. **T0831 Manipulation of Control** — the vendor's own vulnerability text for CVE-2022-31479/31481/31483/31486 states the attacker "can monitor all communications..., modify onboard relays, change configuration files." For an access-control panel, "modify onboard relay" means unlock the door strike or maglock — this is the direct physical-consequence step, equivalent to a PLC output-coil write on a process controller.
4. **T0809 Data Destruction** — CVE-2022-31484 (unauthenticated user deletion) is a built-in anti-forensics/denial-of-access primitive: delete the admin account, lock legitimate operators out of the panel, and force a physical-presence recovery (dip switch + 5-minute login window) before they can regain control — a meaningful response-time penalty during an active incident.
5. **T0814 Denial of Service** — CVE-2022-31482 is explicitly automatable into a "persistent DoS, effectively rendering the target controller useless," per the vendor's own synopsis. Against a door controller, sustained DoS is itself a physical-security failure mode (fails to a known state, which may be locked-and-unreachable or unlocked, depending on configured fail-safe/fail-secure wiring).
6. **T0812 Default Credentials** — worth flagging but not confirmed as a shipped default: Carrier's own mitigation screenshot in CARR-PSA-006-0622 (the "Users" tab of an LNL-X4420 web UI) shows a demonstration account literally named `tester` with a notes-field password hint of `Lenel~123`. This is clearly lab/documentation content, not evidence that panels ship with that exact credential — but it illustrates a predictable `<Brand>~<number>` password convention that is worth testing for during any future hands-on assessment of panels from this dataset.

Logging / detection matrix (highest priority for access-control panels)

Ordered by detection value given what is actually monitorable on a Mercury-class panel — there is no process historian or EWS equivalent here, so detection leans on panel-native logs, the host access-control software's event stream, and OSDP bus behavior.

#	Source	Event	What it catches	MITRE ATT&CK ICS
1	**Access-control software event log** (OnGuard/Synergis/C•CURE/Doors.NET "Host Comm")	Panel goes offline then reappears with a different firmware-version string, or an unscheduled reboot with no maintenance ticket	Unauthenticated firmware push (CVE-2022-31480) or DoS-triggered reboot (CVE-2022-31482)	T0857 System Firmware / T0814 Denial of Service
2	Access-control software event log	**Door Forced Open** or **Door Held Open** alarm with no corresponding valid-badge	Relay-level tamper — the physical consequence of a successful command-	T0831 Manipulation of Control

#	Source	Event	What it catches	MITRE ATT&CK ICS
		or REX event in the same window	injection/path-traversal chain	
3	Access-control software event log	Operator/admin account deleted or lockout event with no change-ticket	CVE-2022-31484-style unauthenticated user deletion, or post-exploitation self-lockout to block response	T0809 Data Destruction
4	**Network IDS (Suricata/Zeek)**	Inbound HTTP/HTTPS to a panel's management port from outside the designated access-control-management VLAN/jump host	Direct exploitation of any of the six unauthenticated 2022 CVEs	T0819 Exploit Public-Facing Application
5	Network IDS	Repeated malformed HTTP requests or update-file uploads to the same panel IP in a short window	CVE-2022-31481/31482-style buffer-overflow or DoS attempts	T0814 Denial of Service
6	**OSDP bus monitoring** (where a reader-side tap or Secure Channel audit exists)	Install Mode re-enabled outside a scheduled commissioning window; a reader's capability reply suddenly reports no encryption support	OSDP key-renegotiation impersonation / Secure-Channel downgrade (Bishop Fox "Badge of Shame" class)	T0831 Manipulation of Control
7	Access-control software event log	Route/routing-table change event (`edit_route.cgi`) outside a documented network-change window	CVE-2022-31486 authenticated command injection via the routing CGI	T0836 Modify Parameter
8	Firewall / network segmentation	Any Mercury panel IP originating outbound traffic to a non-RFC1918 destination	Panels should never initiate connections to the internet; outbound traffic is a strong compromise indicator (same logic CISA used for UPS exposure in 2022)	T0857 System Firmware

Secondary:

- Panel web UI → Diagnostic tab has an "Enable Diagnostic Logging" checkbox (visible in the Carrier PSA screenshots) — turn this on and forward via syslog if the panel firmware/host-comm software supports it.
- The dip-switch physical-recovery procedure (Switch 1 → "on," 5-minute login window) used for both normal admin recovery *and* post-lockout recovery means **a pattern of physical-presence recovery events** logged against a panel is itself worth correlating — legitimate maintenance should be infrequent and scheduled.

- Credential-convention check: given the `tester` / `Lenel~123`-style account visible in vendor documentation, any hands-on assessment of panels from this dataset should explicitly test for predictable or leftover installer accounts before assuming the web-UI auth boundary is intact.

Specific concerns for this dataset

1. **252 devices makes Mercury Security a top-tier OT vendor in this census — ahead of most traditional industrial-process vendors.** The ARNG's 5,723-device nationwide OT & Building Systems inventory is dominated by building-automation and physical-security hardware, not PLCs and relays; Mercury's 252-device footprint (OUI "MERCURY SECURITY CORPORATION") sits alongside Tridium, Johnson Controls, Bosch Security, Axis, and Aiphone as the vendors that actually define this population. A firmware brief program built only around Rockwell/SEL/Siemens-style process-control vendors would have missed the majority of what is actually deployed.
2. **These are door-actuating devices — a successful compromise is not "just" a data-confidentiality event.** The CVE-2022-31479/31481/31483/31486 cluster gives an attacker the ability to "modify onboard relays" per the vendor's own text. At 252 panels, that is potentially 252 sets of physical door hardware (armories, server rooms, controlled-access buildings on National Guard facilities) that could be forced open, or conversely locked to deny legitimate entry/egress, depending on fail-safe/fail-secure wiring — a life-safety and physical-security consequence, not just an IT one.
3. **The OEM-rebadge pattern means the census's OUI-based vendor tag ("Mercury Security Corporation") may undercount true exposure.** Any panel in this inventory that resolved under a different OUI/vendor string but is actually Carrier/LenelS2, Honeywell/Pro-Watch, Genetec/Synergis, or Keri Doors.NET hardware built on Mercury boards would not show up under the "Mercury Security" vendor tag at all, yet would carry the identical CVE-2022-31479…31486 exposure. A cross-check of the inventory against known OEM MAC-prefix ranges (or a sample of web-UI banner grabs) would be needed to find that overlap — this brief did not have inventory access to perform that check.
4. **No CVE activity since June 2022 is a double-edged signal.** It may mean the LP/EP firmware line has genuinely had no further disclosed bugs, or it may mean (as with the Eaton NmcKA family) that a stable, still-deployed product line has simply not attracted further public research. Given the 252-device count and the severity of the 2022 cluster (three CVSS ≥9.1 findings, one at 10.0), confirming actual deployed firmware versions against the 1.271/1.29/1.302/1.303 (LP) and 1.29x/1.296/1.297 (EP) fix thresholds should be the first concrete follow-up action, ahead of any firmware-binary acquisition effort.
5. **MR-series board firmware remains an open research gap.** No CVE was found against the downstream reader/SIO boards specifically, and this project has not verified HID Global's/Genetec's claim that current MR-series hardware defaults Install Mode to off. Given 252 LP/EP-class controllers in this inventory almost certainly drive a larger number of MR boards and readers downstream, this is worth a dedicated OSDP-bus assessment once physical access to a sample site is available — something no amount of further CVE research alone will resolve.

Sources

- CISA ICS Advisory ICSA-22-153-01 — HID Mercury Access Panels sold by LenelS2

- Carrier Product Security Advisory CARR-PSA-006-0622 — HID Mercury Vulnerabilities
- Honeywell Security Notice SN-2022-06-02 #01 — Multiple Vulnerabilities in HID Mercury Intelligent Controllers (LenelS2-integrated products)
- Genetec Security Advisory — Critical Vulnerabilities Affecting HID Mercury Controllers
- Keri Systems — Notice Regarding Mercury Security Firmware Vulnerability
- The Hacker News — Researchers Disclose Critical Flaws in Industrial Access Control System from Carrier
- Security Affairs — HID Mercury Access Controller flaws could allow attackers to unlock doors
- CVE records: CVE-2022-31479 · CVE-2022-31480 · CVE-2022-31481 · CVE-2022-31482 · CVE-2022-31483 · CVE-2022-31484 · CVE-2022-31485 · CVE-2022-31486
- CISA — CISA Releases Seven Industrial Control Systems Advisories (May 30, 2024) — includes ICSA-24-151-01 LenelS2 NetBox, a separate software product, not Mercury panel firmware
- Security Industry Association — Black Hat 2023 Session Underscores Importance of Implementing OSDP Properly (Bishop Fox "Badge of Shame")
- MITRE ATT&CK for ICS — T0819 Exploit Public-Facing Application
- MITRE ATT&CK for ICS — T0857 System Firmware
- MITRE ATT&CK for ICS — T0831 Manipulation of Control
- MITRE ATT&CK for ICS — T0809 Data Destruction
- MITRE ATT&CK for ICS — T0814 Denial of Service
- MITRE ATT&CK for ICS — T0812 Default Credentials
- MITRE ATT&CK for ICS — T0836 Modify Parameter
- purdue-l1-basic-controllers-brief.md — cross-reference for the L1 field-device Purdue role

---

php2shell (CVE-2026-109618 / CVE-2026-109619) determination - 2026-10-22

php2shell context: this brief's PHP determination was driven by CVE-2026-109618 / CVE-2026-109619 ("php2shell", CVSS 9.2, PHP 5.4+, emergency-patched 2026-10-21). Those two IDs are carried here **as supplied by the requester** - they were not independently corroborated against NVD/MITRE in this pass, and no vendor-specific CVE was invented to pair with them.

Firmware analysed: `ep1501_1_29_1_0633.crc`, **1,923,496 bytes**, SHA256 `0d1a67a725b0979239da697e5e8855d919c365d2f819db6c4d27ffb064affab8`, staged at `firmware-staging/Mercury-Security/Access-Control/EP-Series-Panels/raw/`. Acquired in a prior pass; HID's partner portal is GATED, so this file is the only Mercury artefact available and was not re-downloaded. `file` reports generic `data`; the container is proprietary (magic `10 26 19 25`).

binwalk 3.1.0 signature scan - no filesystem or compression container matched. What it did identify, all consistent with a genuine Mercury image: `Copyright (c) Mercury Security Products, LLC, 2016` at offsets 0x3E and 0x171F76, zlib (`Copyright 1995-2005 Jean-loup Gailly` / `Mark Adler`), AES S-Box at 0x18C21C and 0x18C91C, SHA256 constants at 0x16A928, CRC32 polynomial tables. 2,843 strings of >=8 chars in 1.9 MB - readable, so not encrypted at rest.

PHP finding: CONFIRMED ABSENT. All five checks returned zero:

Check	Hits
`.php` filenames	0
`php-cgi` / `bin/php` / `/php`	0
`X-Powered-By`	0
`php.ini`	0
catch-all `strings -n 8 | grep -i php`	**0**

What the web stack actually is: a minimal embedded HTTP server - `HTTP/1.0`, `HTTP/1.1`, `Server:`, `WWW-Authenticate: Basic realm = "`, `Content-type: application/xml`, `X-Content-Type-Options: nosniff`. HTTP Basic auth serving XML, no scripting interpreter. No Linux/VxWorks/FreeRTOS/busybox fingerprint, so bare-metal or a stripped RTOS.

Verdict: EP1501 is OUT OF SCOPE for php2shell. Caveat: this is one panel at firmware 1.29.1 build 0633. LP-series and MR-series boards are unanalysed, and a newer EP firmware could in principle differ.